



Информационная безопасность и защита информации

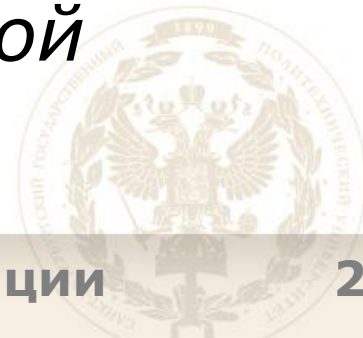
**Идентификация, аутентификация и
управление доступом. Модели безопасности**

Нестеров С.А.
каф. «Системный анализ
и управление»

НСД

Защита информации от несанкционированного доступа –

защита информации, направленная на предотвращение получения защищаемой информации заинтересованными субъектами с нарушением установленных нормативными и правовыми документами (актами) или обладателями информации прав или правил разграничения доступа к защищаемой информации.



НСД

Способы защиты:

- идентификация и аутентификация;
- управление доступом;
- другие способы.

Обычно уточняется, что НСД осуществляется с использованием штатных средств АС.

Например, от утечки информации по каналам связанным с побочным электромагнитным излучением мы таким образом не защитимся.



Идентификация

Идентификация — процедура распознавания субъекта (в частности – пользователя) по его идентификатору.

В процессе регистрации субъект предъявляет свой идентификатор системе, которая проверяет его наличие в своей базе данных. Субъекты с известными системе идентификаторами считаются легальными (законными), остальные относятся к нелегальным.

Также может проводиться идентификация ресурсов АС.

Аутентификация

Аутентификация — процедура проверки подлинности субъекта, которая позволяет достоверно убедиться в том, что субъект, предъявивший идентификатор, на самом деле является именно тем субъектом, идентификатор которого он использует.



Управление доступом и авторизация

Управление доступом – метод защиты информации путем регулирования использования всех ресурсов системы.

Авторизация — процедура предоставления субъекту определенных прав доступа к ресурсам системы после прохождения им процедуры аутентификации. Для каждого субъекта в системе определяется набор прав, которые он может использовать при обращении к ее ресурсам.



Аудит доступа к ресурсам

Аудит (аудит доступа) — процесс контроля (мониторинга) доступа субъектов к ресурсам системы, включающий протоколирование действий субъектов при их доступе к ресурсам системы в целях обнаружения несанкционированных действий.



Аутентификация: 3 группы методов

Аутентификация по наличию у пользователя уникального объекта заданного типа.

*Иногда этот класс методов аутентификации называют по-английски — *I have* («у меня есть»).*

Например, аутентификация с помощью смарт-карт или электронных USB-ключей.



Аутентификация: 3 группы методов

Аутентификация, основанная на том, что пользователю известна некоторая конфиденциальная информация – I know («я знаю»).

Например, аутентификация по паролю.



Аутентификация: 3 группы методов

Аутентификация пользователя по его собственным уникальным характеристикам – —I am («я есть»). Эти методы также называются **биометрическими**.

Биометрические методы аутентификации:

- статические
 - проверка отпечатка пальца, рисунка радужной оболочки глаз, геометрии кисти руки и т.д.
- динамические
 - по голосу, рукописному или «клавиатурному» почерку и т.д.



Двухфакторная аутентификация

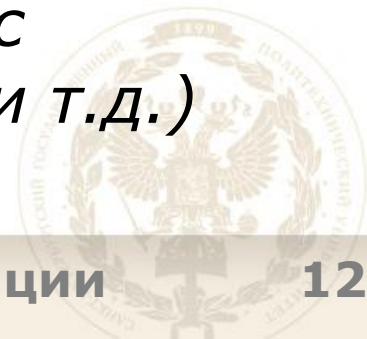
Для повышения надежности совместно используются методы 2-х типов.

Например, электронный ключ и пароль.



Аутентификация

- *Односторонняя (проверяется только одна сторона)*
 - *проверка пользователя при входе в систему*
- *Двусторонняя (стороны проводят взаимную проверку подлинности)*
 - *в распределенной системе может проверяться подлинность и того, кто подключается, и того, к кому подключаются (Kerberos, SSL с проверкой обеих сторон соединения и т.д.)*



Аутентификация

- *Непосредственная*
- *С участием доверенной стороны (сервера аутентификации)*



Аутентификация

- *Непосредственная*
- *С участием доверенной стороны (сервера аутентификации)*



Парольные системы аутентификации

Идентификатор пользователя

Пароль пользователя

- системы с одноразовыми паролями
- системы с многоразовыми паролями

Учетная запись пользователя



Парольные системы аутентификации

Парольная система – это программный или программно-аппаратный комплекс, реализующий функции идентификации и аутентификации пользователей компьютерной системы путем проверки паролей.

Модули:

- Интерфейс пользователя
- Интерфейс администратора
- База учетных записей
- Модули сопряжения



Рекомендации по администрированию парольной системы (многобразовые пароли)

- 1. Задание минимальной длины используемых в системе паролей.*
- 2. Установка требования использовать в пароле разные группы символов – большие и маленькие буквы, цифры, специальные символы.*
- 3. Периодическая проверка администраторами безопасности качества используемых паролей путем имитации атак.*



Рекомендации по администрированию парольной системы (многобразовые пароли)

4. Установка максимального и минимального сроков жизни пароля, использование механизма принудительной смены старых паролей.
5. Ограничение числа неудачных попыток ввода пароля.
6. Ведение журнала истории паролей.



Дополнительно

Аутентификация. Теория и практика обеспечения безопасного доступа к информационным ресурсам. Учебное пособие для вузов / А. А. Афанасьев, Л. Т. Веденьев, А. А. Воронцов и д.р.; Под ред. А. А. Шелупанова, С. Л. Груздева, Ю.С. Нахаева. — М.: Горячая линия—Телеком, 2009.



Модели безопасности

Политика безопасности – совокупность документированных правил, процедур, практических приемов или руководящих принципов в области безопасности информации, которыми руководствуется организация в своей деятельности.

Формальное описание политики безопасности производится в рамках модели безопасности.



Сущность, субъект, объект

Сущность – любая именованная составляющая защищаемой АС.

Субъект – активная сущность, которая может инициировать запросы ресурсов и использовать их для выполнения каких-либо вычислительных операций.

Объект – пассивная сущность, используемая для хранения или получения информации.



Сущность, субъект, объект

Доступ – взаимодействие между субъектом и объектом, в результате которого производится перенос информации между ними.

Типы доступа:

Read – доступ на чтение из сущности;

Write – доступ на запись в сущность;

Append – доступ на запись в конец слова, описывающего состояние сущности;

Execute – доступ на активизацию субъекта из сущности.



Основная аксиома компьютерной безопасности

Все вопросы безопасности информации в компьютерной системе описываются доступами субъектов к сущностям.

Все действия в КС, в том числе выполнение операций над сущностями, порождение информационных потоков, изменение параметров и настроек системы защиты КС, порождение новых субъектов, могут быть инициированы только субъектами КС с использованием доступов к сущностям КС.

Все информационные потоки в КС порождены доступами субъектов к сущностями.



Модели безопасности

Типы управления доступом:

- 1. дискреционное (избирательное);*
- 2. мандатное;*
- 3. ролевое.*

